SISTEMI E RETI · SICUREZZA INFORMATICA

I sei principi della sicurezza

Che cosa vuol dire, esattamente, che un sistema è "sicuro"? Sei parole per rispondere con precisione.

CHE COSA PROTEGGIAMO

La sicurezza protegge informazioni e servizi

Non esiste un sistema "sicuro" in assoluto: esiste un sistema che rispetta certi **principi** contro certe **minacce**.

Dati

Voti, cartelle cliniche, conti correnti, foto, messaggi privati.

Servizi

Registro elettronico, home banking, posta, sito della scuola.

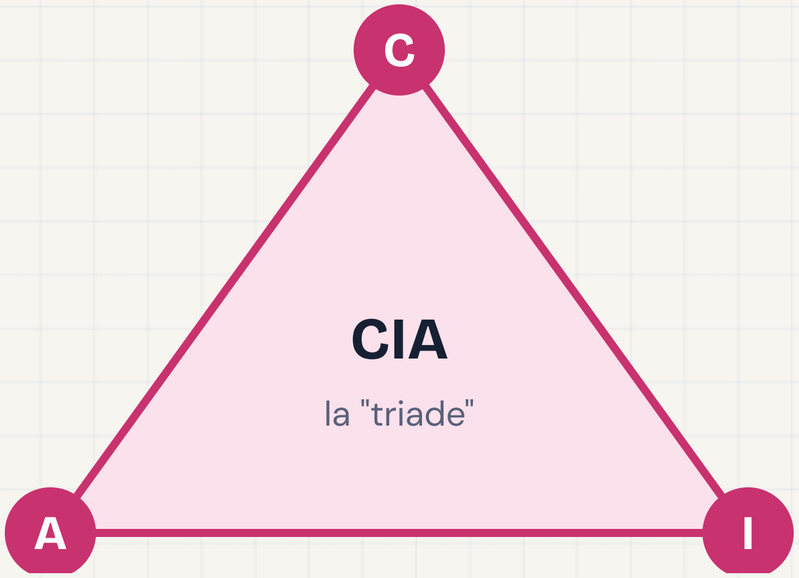
Persone

Chi usa i sistemi: identità, reputazione, privacy.

Per ogni principio vedremo: **definizione**, **esempio**, **minaccia** tipica e **contromisura**.

LA MAPPA DELLA LEZIONE

Tre proprietà, tre meccanismi



Confidentiality = riservatezza · **I**ntegrity = integrità · **A**vailability = disponibilità

Autenticazione

Sei davvero chi dici di essere?

Autorizzazione

Che cosa ti è permesso fare?

Non ripudio

Non puoi negare di averlo fatto.

PRINCIPIO 1 · C

Riservatezza: legge solo chi ne ha diritto

L'informazione è accessibile **solo** alle persone, ai processi e ai sistemi autorizzati.

Esempio

I voti di uno studente li vedono lui, la famiglia e i docenti. Non i compagni.

Minaccia

Intercettazione su una Wi-Fi aperta, furto di un portatile, cartella condivisa "con tutti".

Contromisura

Cifratura dei dati e delle comunicazioni, controllo degli accessi.

> Chi tratta dati personali (scuole, ospedali, aziende) ha anche l'**obbligo di legge** di proteggerne la riservatezza: lo impone il GDPR.

PRINCIPIO 2 · I

Integrità: nessuno altera i dati di nascosto

L'informazione è **completa e corretta**: non viene modificata da chi non è autorizzato, e se succede ce ne accorgiamo.

Esempio

Un bonifico di 50 € deve arrivare come 50 €, allo stesso destinatario.

Minaccia

Un malware o un intermediario cambia un dato in transito o sul disco.

Contromisura

Hash e firma digitale per accorgersi delle modifiche, permessi di sola lettura.

> Integrità non vuol dire che il dato non cambia mai: cambia **solo** chi è autorizzato, e la modifica si può verificare.

AL COMPUTER · 15 minuti

L'impronta di un file con SHA-256

1. Con il Blocco note crea `voto.txt` con il testo `Verifica di Mario Rossi: 6` e salvalo in Documenti.
2. Nella barra degli indirizzi di Esplora file scrivi `cmd` e premi Invio, poi esegui `certutil -hashfile voto.txt SHA256`.
3. Copia l'hash nella cella A2 di un foglio Calc.
4. Cambia il 6 in 9, salva, ricalcola l'hash e copialo in B2.
5. In C2 scrivi `=SE(A2=B2;"uguali";"diversi")`. Salva come **hash-Cognome.ods**.

Da PowerShell

`Get-FileHash voto.txt`
usa SHA-256 se non indichi altro.

Controllo: ogni hash ha 64 caratteri (0-9, a-f). Basta una cifra cambiata e i due hash non si somigliano più. Rimetti il 6 e ricalcola: torna identico al primo.

PRINCIPIO 3 · A

Disponibilità: il servizio c'è quando serve

Le persone autorizzate possono usare dati e servizi **nel momento in cui ne hanno bisogno**.

Esempio

Il registro elettronico deve funzionare proprio durante gli scrutini.

Minaccia

Attacco DDoS, ransomware che blocca i file, guasto al disco, blackout.

Contromisura

Backup, server e dischi ridondanti, gruppo di continuità (UPS).

La disponibilità si perde anche **senza attaccanti**: un disco rotto, un incendio o un errore di configurazione bastano.

ATTENZIONE

I tre principi a volte si scontrano

Più controlli

Una password richiesta ogni 5 minuti protegge la riservatezza ma rende il servizio scomodo: **disponibilità** peggiore.

Più copie

Tanti backup aiutano la disponibilità, ma ogni copia è un posto in più da proteggere: **riservatezza**.

Chiave persa

Dati cifrati benissimo, ma se perdi la chiave nessuno li legge più, nemmeno tu.

Progettare la sicurezza significa trovare un **equilibrio** adatto a quel sistema.

PRINCIPIO 4

Autenticazione: dimostra chi sei

Il sistema verifica che l'utente sia davvero chi dichiara di essere, usando uno o più **fattori**.

1

Qualcosa che sai

Password, PIN, risposta segreta.

2

Qualcosa che hai

Telefono con app, chiavetta di sicurezza, carta d'identità elettronica.

3

Qualcosa che sei

Impronta digitale, volto.

Minaccia password rubata o indovinata **Contromisura** **MFA**: almeno due fattori di tipo diverso

AL COMPUTER · 10 minuti

Attiva la verifica in due passaggi

1. Accedi al tuo account Google della scuola e apri `myaccount.google.com`.
2. Nella casella di ricerca dell'account scrivi **Verifica in due passaggi** e aprila.
3. Segui la procedura: scegli come secondo passaggio la notifica sul telefono o un'app di autenticazione.
4. Genera i **codici di backup** e conservali in un posto sicuro, non sul PC della scuola.
5. Annota in un documento **mfa-Cognome** quali fattori hai attivato e a quale categoria appartengono.

Perché i codici di backup?

Se perdi il telefono, sono l'unico modo per rientrare senza chiedere aiuto all'amministratore.

Controllo: apri una finestra in incognito e accedi di nuovo: dopo la password, Google ti chiede il secondo passaggio.

PRINCIPIO 5

Autorizzazione: che cosa puoi fare

Dopo l'autenticazione, il sistema decide **a quali risorse** l'utente può accedere e **con quali operazioni**.

Esempio

Nel registro lo studente legge i voti, il docente li inserisce, la segreteria gestisce le iscrizioni.

Minaccia

Permessi dati "a tutti" per comodità; un utente che ottiene privilegi che non dovrebbe avere.

Contromisura

Minimo privilegio: a ciascuno solo i permessi che servono. Permessi per ruolo, rivisti spesso.

Al cinema: il documento all'ingresso è l'**autenticazione**, il biglietto per la sala 3 è l'**autorizzazione**.

PRINCIPIO 6

Non ripudio: non puoi negare di averlo fatto

Chi ha inviato un messaggio o eseguito un'azione **non può negarlo** in seguito, perché esiste una prova valida.

Esempio

La **PEC** rilascia ricevute di invio e di consegna che hanno valore legale.

Minaccia

"Quel contratto non l'ho mai firmato", "quell'ordine non l'ho mandato io".

Contromisura

Firma digitale, marca temporale, registri (log) protetti da modifiche.

Una normale e-mail **non** garantisce il non ripudio: il mittente si può falsificare e non c'è prova certa della consegna.

METTIAMOLI IN FILA

Che cosa succede quando accedi a un servizio

1

Identificazione

Dici chi sei: il nome utente.

2

Autenticazione

Lo dimostri: password e secondo fattore.

3

Autorizzazione

Il sistema decide che cosa puoi fare.

4

Tracciamento

Ogni azione resta nei log, con data e ora.

Il tracciamento è la base del **non ripudio**: senza registri affidabili non si può provare chi ha fatto che cosa.

NON CONFONDETEVI

I libri li raggruppano in modi diversi

I concetti sono gli stessi, cambiano il numero e i nomi. Se un testo ne elenca 3, 5 o 6, non è un errore.

Modello	Che cosa elenca
Triade CIA	Riservatezza, integrità, disponibilità
AAA (reti)	Autenticazione, autorizzazione, accounting (tracciamento)
Esade di Parker	CIA più possesso (controllo), autenticità, utilità
ISO/IEC 27000	CIA, e in più può includere autenticità, responsabilità, non ripudio, affidabilità

In questa lezione: la triade CIA più autenticazione, autorizzazione e non ripudio.

AL COMPUTER · 15 minuti

Quale principio è stato violato?

#	Scenario
1	Il sito della scuola resta irraggiungibile per tutta la mattina, sommerso di richieste.
2	Qualcuno cambia un voto nel registro dopo che il docente l'ha inserito.
3	Un cliente sostiene di non aver mai firmato un contratto online.
4	Un compagno entra nella tua posta con la password letta su un post-it.
5	Uno studente apre la pagina dei docenti cambiando l'indirizzo nel browser.
6	Viene rubato un portatile non cifrato con i dati dei pazienti di un medico.

In Calc crea le colonne **Scenario · Principio · Contromisura** e compila una riga per scenario. Salva come **principi-Cognome.ods**.

Controllo: ognuno dei sei principi compare almeno una volta nella colonna Principio.

RIPASSO

I sei principi in breve

Riservatezza

Legge solo chi può. Cifratura, controllo accessi.

Integrità

Nessuna modifica di nascosto. Hash, firma digitale.

Disponibilità

C'è quando serve. Backup, ridondanza.

Autenticazione

Dimostra chi sei. MFA.

Autorizzazione

Solo ciò che ti spetta. Minimo privilegio.

Non ripudio

Non puoi negarlo. Firma digitale, log.